Registration flow (POST /auth/register): The request hits AuthController, which encodes the password using BCryptPasswordEncoder, then calls UserService.registerUser() to persist the User entity via UserRepo. Returns true with HTTP 201.

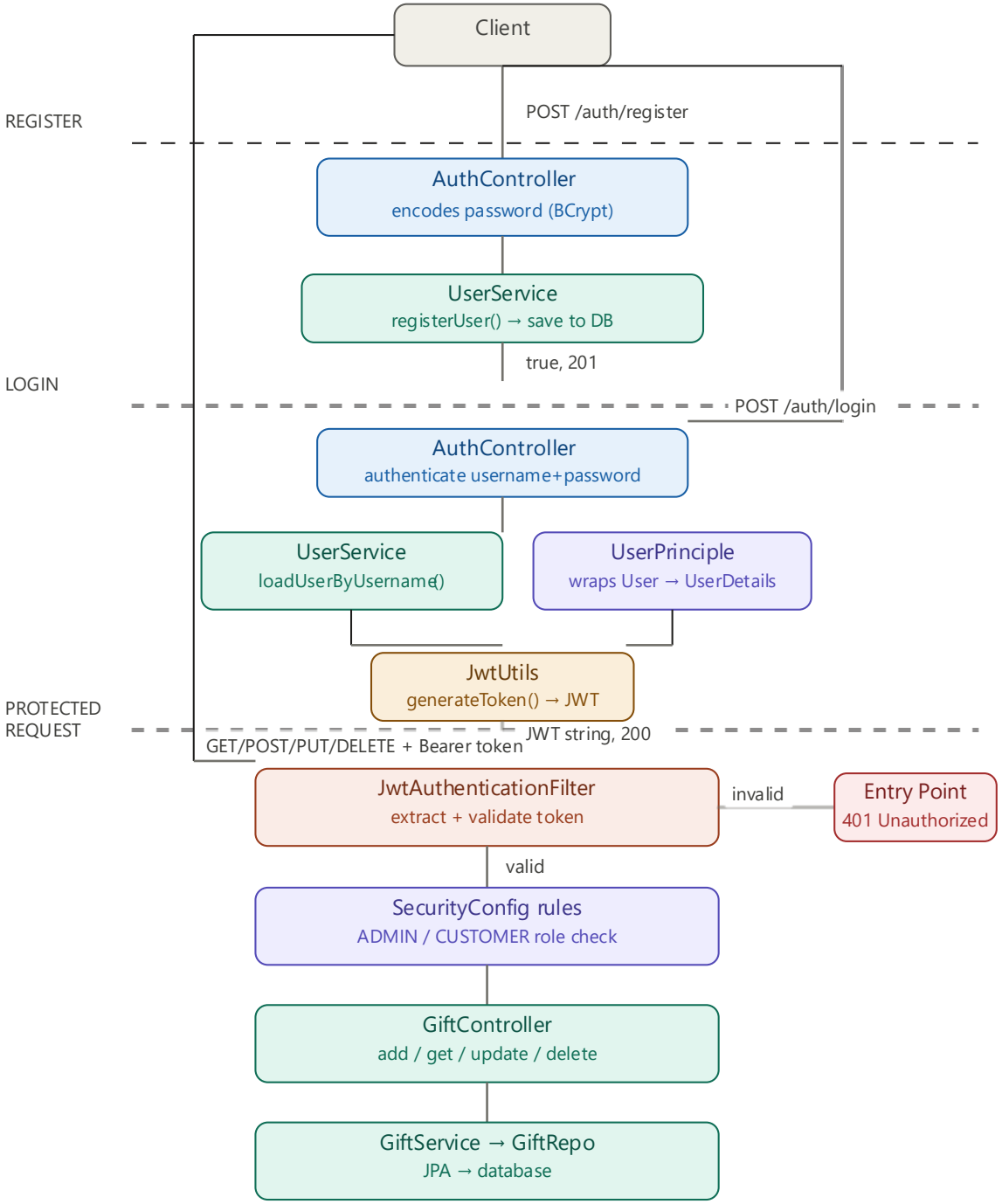
Login flow (POST /auth/login): AuthController delegates to AuthenticationManager, which internally calls UserService.loadUserByUsername(). That fetches the user from UserRepo and wraps it in a UserPrinciple object (which implements UserDetails).

Spring Security compares the encoded passwords. On success, JwtUtils.generateToken() creates a signed HS256 token valid for 1 hour and returns it in the response.

Authenticated request flow (any protected endpoint): Every request passes through JwtAuthenticationFilter first. It extracts the Bearer token, uses JwtUtils to validate the signature and expiry, loads the user, and sets the Authentication object in Spring's SecurityContextHolder.

The request then reaches SecurityConfig's authorization rules — /api/gift (POST) requires ROLE_ADMIN, while /api/gift/** (GET, PUT, DELETE) allows both ROLE_ADMIN and ROLE_CUSTOMER. If the token is missing or invalid, JwtAuthenticationEntryPoint fires back a 401 Unauthorized.

Gift operations: Once past the security layer, GiftController delegates everything to GiftService, which is a thin wrapper over GiftRepo (a JpaRepository<Gift, Integer>).



Register — AuthController → BCrypt encode → UserService.registerUser() → DB save → true / 201

Login — AuthController → AuthenticationManager → UserService.loadUserByUsername() → UserPrinciple → JwtUtils.generateToken() → JWT string / 200

Protected request — Every request hits JwtAuthenticationFilter first. Valid token → SecurityContextHolder → SecurityConfig enforces role rules → GiftController → GiftService → GiftRepo. Invalid/missing token → JwtAuthenticationEntryPoint sends back 401 immediately without ever reaching the controller.

One thing worth noting: /api/gift (exact path, no wildcard) is ADMIN-only for POST, but /api/gift/** (with wildcard) allows both ADMIN and CUSTOMER — so a CUSTOMER can read or update a specific gift by ID but cannot create new ones.